



INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Course: BVWS103-OWASP Top 10 Vulnerabilities And
Exploitation Techniques

Student Name: Abubakari-Sadique Hamidu
Student ID: 2025/FWSD/11392

Instructor: Aminu Iddris (CCNA, CompTIA, CEH, OSCP, CISSP, CISM)

Lab 14: Insecure Direct Object Reference (IDOR)

1. Introduction

This lab demonstrates an **Insecure Direct Object Reference (IDOR)** vulnerability in a simple PHP web application.

IDOR occurs when an application exposes internal object references (such as user IDs) without verifying whether the user is authorized to access that data.

The objective of this lab was to:

- Identify an IDOR vulnerability
- Exploit the vulnerability
- Implement proper access control to fix it

2. Vulnerable Application Setup

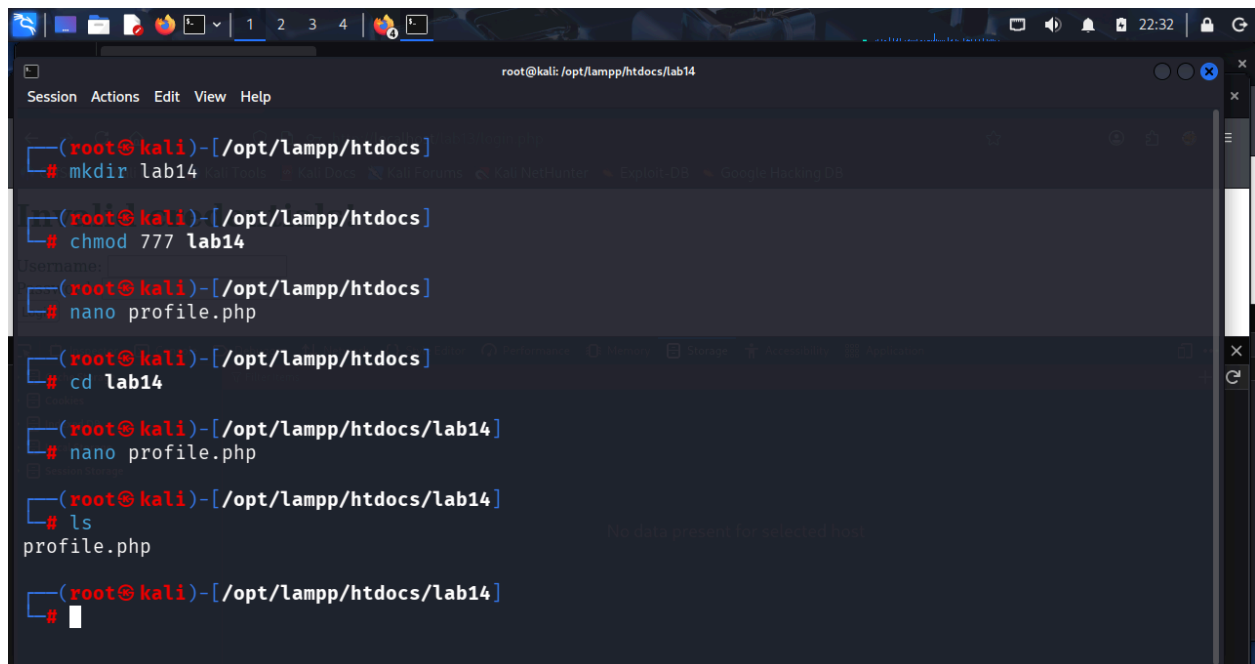
I created lab14 folder was created in /opt/lampp/htdocs

A PHP file (profile.php) was created containing simulated user data.

The application allowed users to access profiles using a URL parameter:

profile.php?user_id=1

The system did not verify whether the logged-in user was authorized to access the requested user ID.



```
root@kali: /opt/lampp/htdocs/lab14
Session Actions Edit View Help

(root@kali)-[/opt/lampp/htdocs]
# mkdir lab14

(root@kali)-[/opt/lampp/htdocs]
# chmod 777 lab14

Username:
(root@kali)-[/opt/lampp/htdocs]
# nano profile.php

(root@kali)-[/opt/lampp/htdocs]
# cd lab14

(root@kali)-[/opt/lampp/htdocs/lab14]
# nano profile.php

(root@kali)-[/opt/lampp/htdocs/lab14]
# ls
profile.php

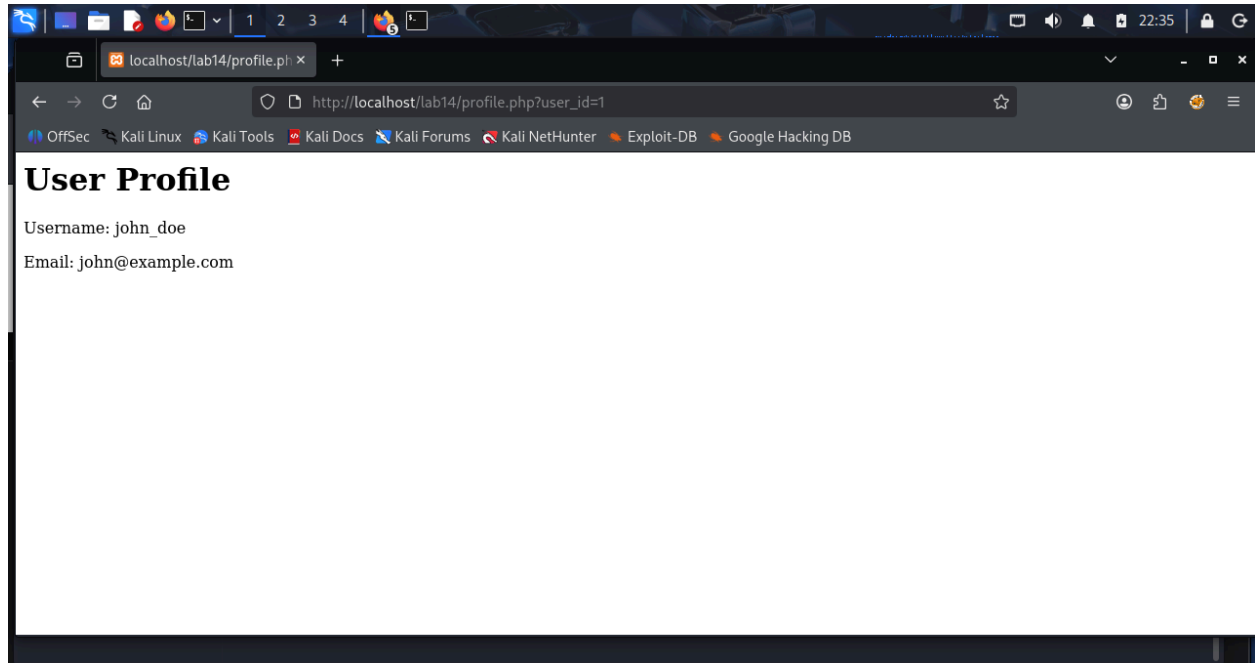
(root@kali)-[/opt/lampp/htdocs/lab14]
#
```

3. Exploiting the IDOR Vulnerability

Step 1: Access Logged-in User Profile

The application was accessed using:
profile.php?user_id=1

The profile of user 1 was displayed successfully.

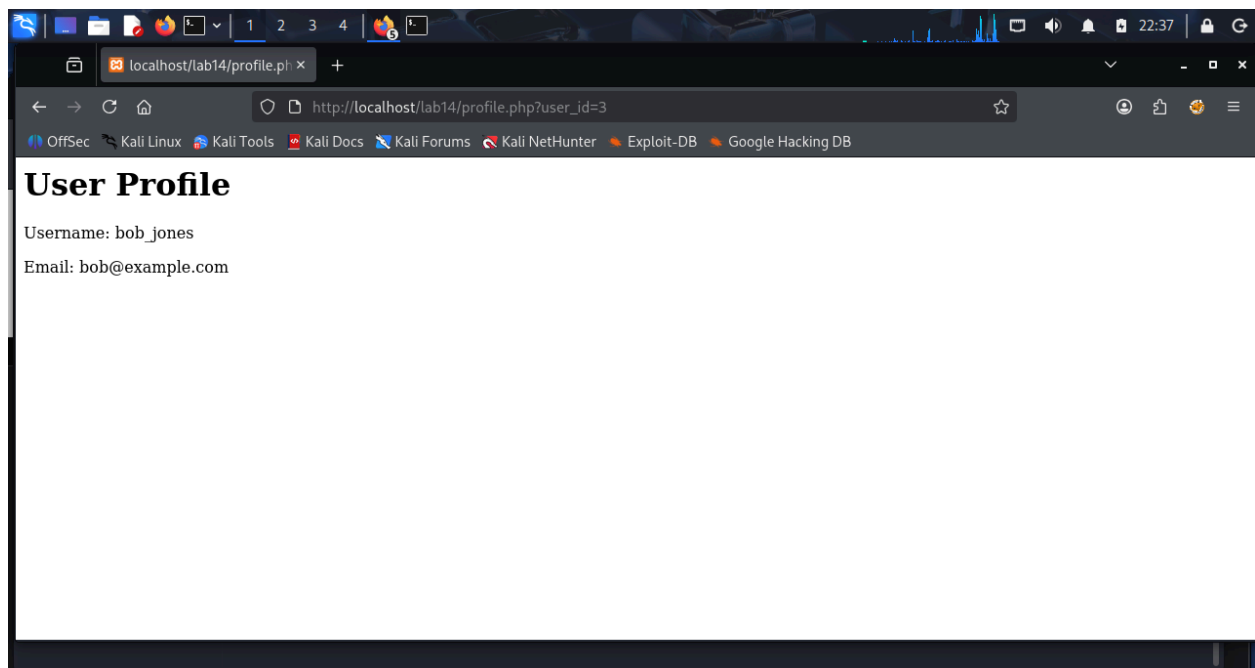
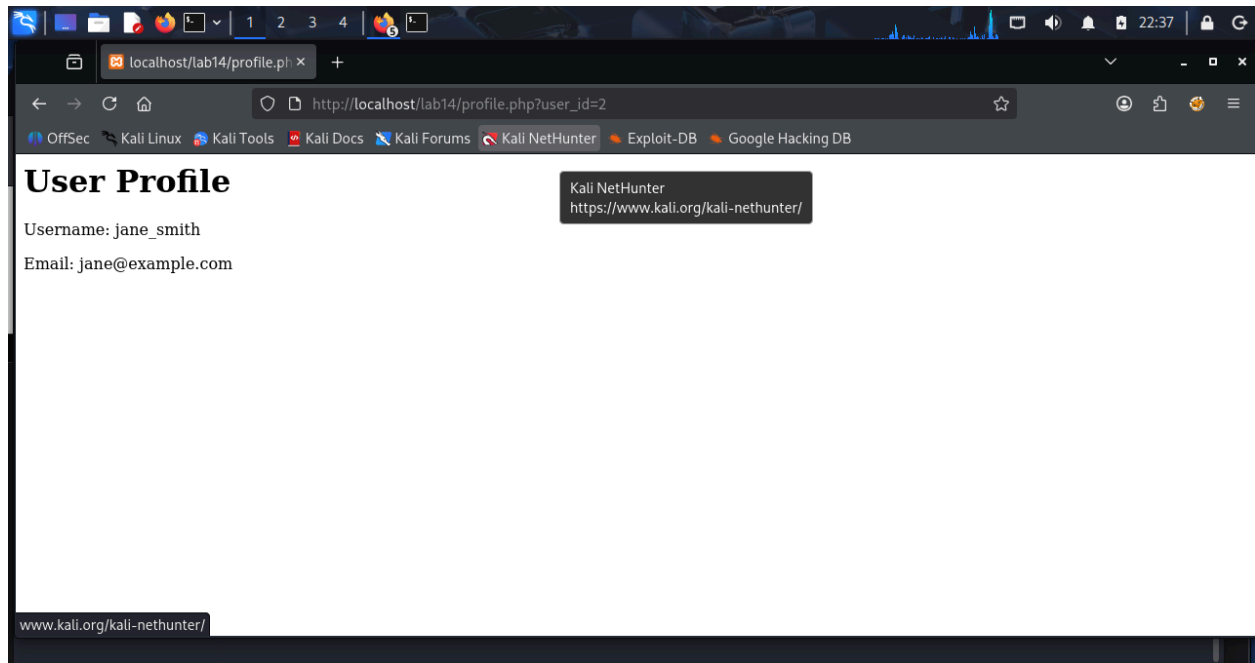


Step 2: Manipulating the URL

The user_id parameter was modified in the URL:
profile.php?user_id=2
profile.php?user_id=3

The application displayed the profiles of other users (Jane and Bob) even though the session user ID was 1.

This confirms the presence of an IDOR vulnerability.



4. Cause of the Vulnerability

The vulnerability occurred because the application trusted user input from the URL and did not verify whether the logged-in user was authorized to access the requested profile.

There was **no access control validation** comparing:

Requested user ID vs Logged-in user ID

This lack of authorization checking allowed unauthorized access to sensitive user data.

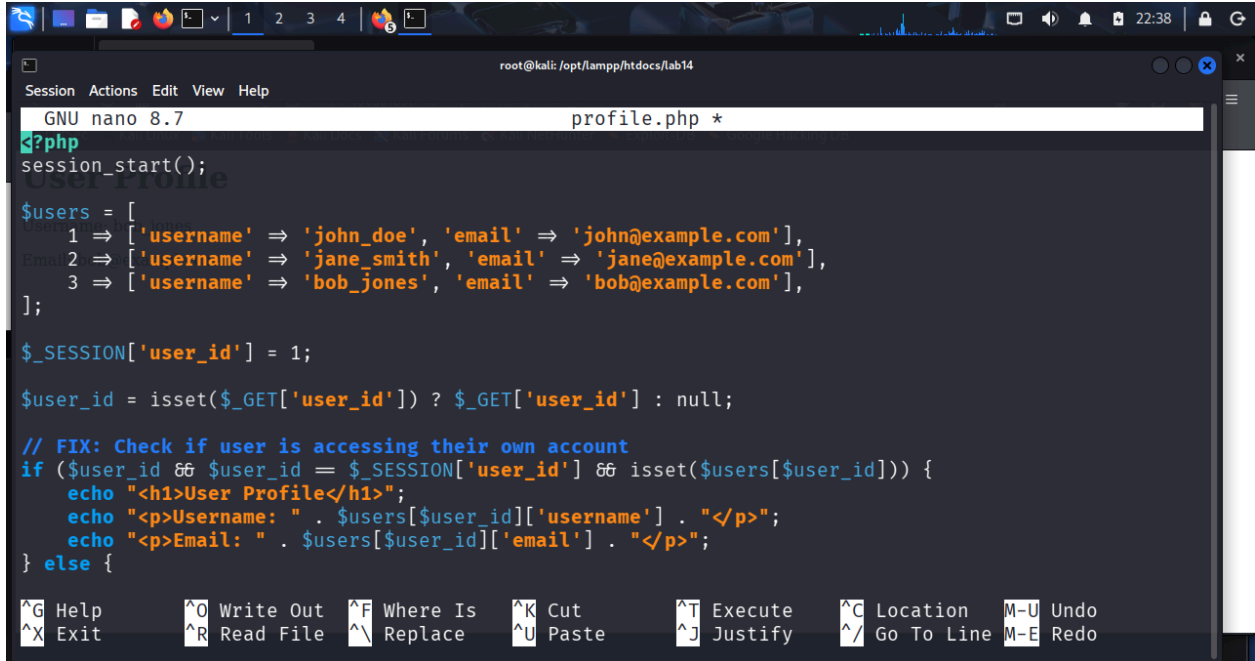
5. Fixing the IDOR Vulnerability

To fix the vulnerability, access control was implemented.

The application was modified to check whether:

```
$user_id == $_SESSION['user_id']
```

If the requested user ID does not match the logged-in user ID, access is denied.



```
GNU nano 8.7 profile.php *
<?php
session_start();

$users = [
    1 => ['username' => 'john_doe', 'email' => 'john@example.com'],
    2 => ['username' => 'jane_smith', 'email' => 'jane@example.com'],
    3 => ['username' => 'bob_jones', 'email' => 'bob@example.com'],
];

$_SESSION['user_id'] = 1;

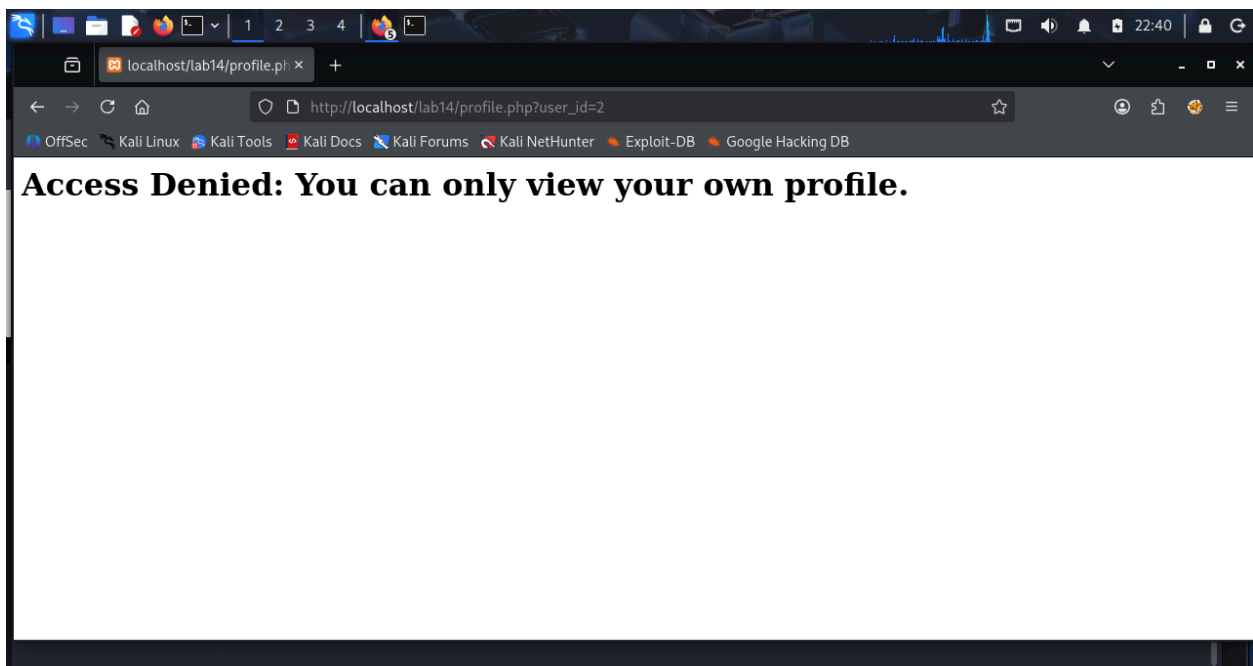
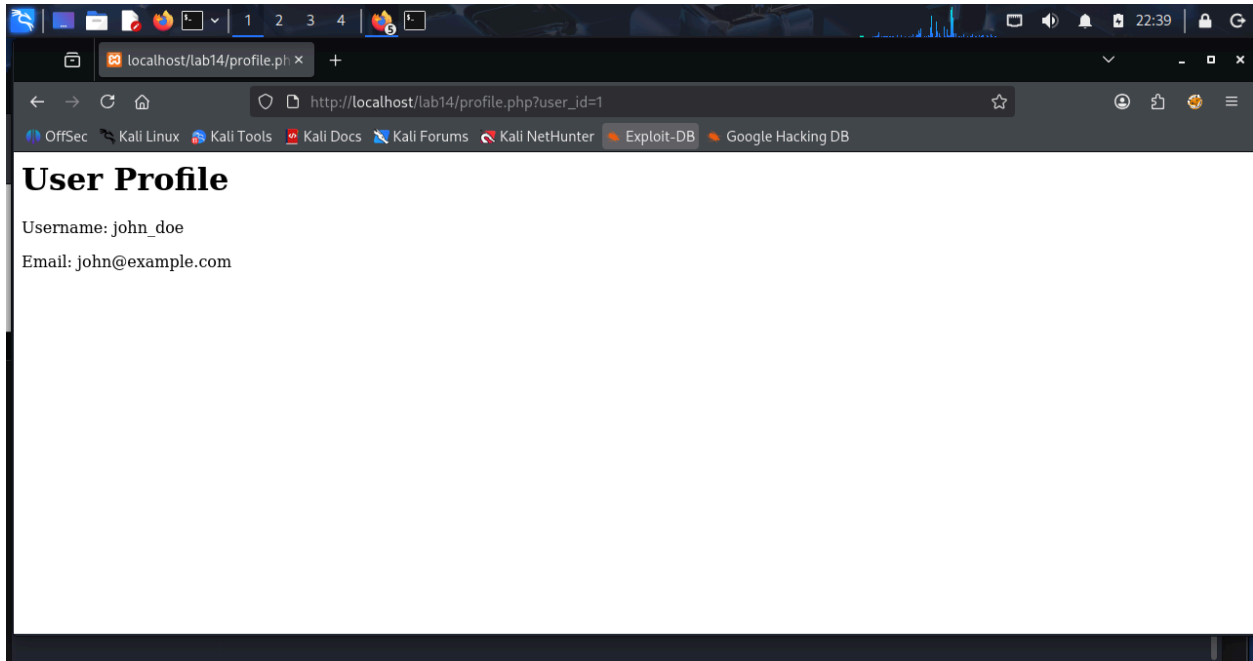
$user_id = isset($_GET['user_id']) ? $_GET['user_id'] : null;

// FIX: Check if user is accessing their own account
if ($user_id && $user_id == $_SESSION['user_id'] && isset($users[$user_id])) {
    echo "<h1>User Profile</h1>";
    echo "<p>Username: " . $users[$user_id]['username'] . "</p>";
    echo "<p>Email: " . $users[$user_id]['email'] . "</p>";
} else {
    // Access Denied
}
```

6. Testing the Fixed Application

After implementing access control:

- profile.php?user_id=1 → Works correctly
- profile.php?user_id=2 → Access Denied
- profile.php?user_id=3 → Access Denied



7. Conclusion

This lab demonstrated how Insecure Direct Object References occur when proper authorization checks are missing.

By implementing access control that verifies the identity of the logged-in user before displaying sensitive information, the vulnerability was successfully mitigated.

Proper authorization validation is essential to prevent unauthorized access to user data in web applications.